Vendor Risk Management Policy

Section 1: Risk Tiers

Suppliers are classified into three risk tiers. Tier 1 (critical) covers suppliers with annual spend above $250,000 or any single-source supplier. Tier 2 covers medium-risk suppliers. Tier 3 covers low-risk suppliers. Tier 1 suppliers are reassessed every 12 months, Tier 2 every 24 months and Tier 3 every 36 months.

Section 2: Due Diligence

Before onboarding, the procurement team must complete a financial health check and a sanctions screening for every new supplier. A supplier that fails the sanctions screening cannot be onboarded under any circumstances.

Section 3: Data Protection

Suppliers that handle personal data of employees or customers must sign a Data Processing Agreement. Any data breach must be reported to the company within 72 hours of discovery.

Section 4: Business Continuity

Tier 1 suppliers must provide a Business Continuity Plan and test it once a year. The test report must be shared with the category manager.

Section 5: Conflict of Interest

Employees must declare any personal or financial interest in a supplier within 5 business days of becoming aware of it. The procurement manager decides whether the employee must step away from the supplier selection.